Maine State Government
Dept. of Administrative & Financial Services
Office of Information Technology (OIT)

Software Development Lifecycle Policy (SDLC)

1.0 Purpose

1.1. To ensure secure, reliable, and resilient software delivery, all application projects shall follow the State of Maine's Software Development Lifecycle (SDLC), which integrates Secure Software Development Lifecycle (SSDLC) security, quality, compliance, and risk management throughout the lifecycle. (As an "SDLC" policy, future reference to Accessibility is anticipated.)

1.2. This Policy requires that any software developed, acquired, configured, hosted, or maintained for the State of Maine implements security controls appropriate to its risk, regardless of development methodology, technology platform, or hosting model. The SDLC provides the governance framework for embedding security into planning, acquisition, development, implementation, operations, maintenance, and retirement activities.

1.3. Mandatory SDLC requirements include application risk profiling, defining security requirements, secure design and development, security testing, deployment controls, vulnerability management, logging, and exception handling. Supporting Standards, Procedures, Templates, and Technical Guidance provide the detailed practices needed to meet these requirements.

1.4. This Policy applies to all software supporting State business operations, including internally developed applications, vendor-provided or vendor-hosted solutions, COTS products, low-code/no-code applications, APIs, integrations, and cloud native services. Because delivery models vary, the Policy establishes technology independent, outcome-based requirements and allows compensating controls when prescribed controls cannot be reasonably implemented.

1.5. Oversight for Secure Software Development Lifecycle is provided by the Information Security Office (ISO), led by the Chief Information Security Officer (CISO). ISO maintains supporting documentation in collaboration with Enterprise Shared Services (ESS) and Application Development leadership to enable consistent implementation and continuous improvement across the enterprise.

2.0 Definitions

2.1 *Application Owner*: The individual or business owner is responsible for the overall management, security, and lifecycle of an application, including ensuring compliance with this Policy and supporting Standards. (See section 4.1 of the Application Deployment Certification Policy[1])

2.2 *Application Project*: A temporary or ongoing effort to develop, acquire, configure, implement, enhance, integrate, or significantly modify an application or software-enabled

[1] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ApplicationDeploymentCertification.pdf

service.

2.3 *Application Risk Profile (ARP)*: The State of Maine's risk-based classification methodology is used to determine the security requirements, governance activities, and level of assurance required throughout the Secure Software Development Lifecycle.

2.4 *Commercial Off-the-Shelf (COTS) Software*: Commercially available software acquired for State of Maine business use that may require configuration, customization, or integration but is not developed specifically for the State of Maine.

2.5 *Low-Code / No-Code (LC/NC) Solution*: An application or automation developed primarily through visual development platforms or configuration-based technologies with limited or no traditional source code.

2.6 *Secure Software Development Lifecycle (SSDLC)*: The governance framework established by the State of Maine for integrating security throughout the planning, acquisition, development, implementation, operation, maintenance, and retirement of software and software-enabled services.

2.7 *Security Gate*: A defined lifecycle checkpoint where required security activities, approvals, or documented exceptions must be completed before an application or software change progresses to the next stage of the lifecycle.

2.8 *Software Delivery Model*: The method by which software is developed, acquired, configured, hosted, maintained, or delivered, including internally developed applications, vendor-developed solutions, vendor-hosted services, commercial software, low-code/no-code solutions, and cloud-native services.

2.9 *Vendor-Hosted Application*: An application or software service operated, developed, hosted, or managed by a third party on behalf of the State of Maine, including Software-as-a-Service (SaaS) and managed application services.

2.10 *Waiver/Exception*: A formally documented and approved acceptance of risk when one or more requirements of this Policy or supporting Standards cannot reasonably be met. All waivers and exceptions shall be managed in accordance with the State of Maine's approved exception management process. (See Waiver Policy[2])

3.0 Applicability

3.1 This Policy applies to all software developed, acquired, configured, hosted, maintained, or operated on behalf of the State of Maine under the authority of the Office of Information Technology (OIT), regardless of the software delivery model, hosting environment, or technology platform.

3.2 This Policy applies to, but is not limited to:

- 3.2.1 State of Maine developed applications
- 3.2.2 Vendor-developed software
- 3.2.3 Vendor-hosted applications and Software-as-a-Service (SaaS) solutions
- 3.2.4 Commercial Off-the-Shelf (COTS) software

[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/Waiver.pdf

3.2.5 Low-Code / No-Code (LC/NC) solutions
3.2.6 Application Programming Interfaces (APIs)
3.2.7 System integrations
3.2.8 Cloud-native services
3.2.9 Mobile applications
3.2.10 Significant application enhancements and custom-developed extensions

3.3 The security requirements established by this Policy shall be implemented in a manner commensurate with the application's risk. The Application Risk Profile (ARP) shall determine the depth and rigor of security activities, governance, testing, documentation, and approval requirements.

3.4 While implementation methods may vary based on technology platforms, software delivery model, or hosting environment, all applications shall achieve the security objectives established by this Policy. Where prescribed technical controls cannot reasonably be implemented, equivalent or compensating controls may be used in accordance with approved Standards and the State of Maine's exception management process.

3.5 Contracts, procurements, and agreements for software or software-enabled services shall require compliance with this Policy and applicable supporting Standards. Vendors shall demonstrate compliance through evidence appropriate to the software delivery model and contractual requirements.

4.0 Roles and Responsibilities

4.1 **Application Owners**: Ensure that applications under their responsibility comply with this Policy throughout the application lifecycle. Responsibilities include:
4.1.1 Ensuring required security activities are completed.
4.1.2 Supporting application risk profiling.
4.1.3 Accepting and managing business risk associated with approved exceptions.
4.1.4 Ensuring required documentation and compliance evidence are maintained.
4.1.5 Supporting governance reviews and audit activities.

4.2 **Enterprise Shared Services (ESS) – Application Development**: Implement the requirements established by this Policy and supporting Standards.

4.3 **Executive Oversight**: Executive oversight of the Secure Software Development Lifecycle Program is provided by the Information Security Office, led by the Chief Information Security Officer (CISO). Strategic direction and enterprise governance are supported through established executive governance processes, including the Executive Steering Committee (ESC), as appropriate.

4.4 **Information Security Office (ISO)**: Provides governance for the State of Maine's Secure Software Development Lifecycle Program. Responsibilities include:
4.4.1 Developing and maintaining supporting Security Standards.
4.4.2 Establishing minimum security requirements applicable to software delivery.
4.4.3 Providing governance, oversight, and compliance monitoring.
4.4.4 Reviewing and approving policy exceptions in accordance with the State of Maine's exception management process.

4.4.5 Collaborating with Enterprise Shared Services (ESS) Application Development teams and business stakeholders to continuously improve the State of Maine's SDLC Program.

4.5 **Vendors and Third-Party Solution Providers**: Organizations developing, configuring, hosting, or maintaining software on behalf of the State of Maine shall comply with the security requirements established by this Policy. Vendors are not required to use specific development tools or methodologies; however, they shall demonstrate that software delivered to the State of Maine satisfies the security outcomes established by this Policy. Evidence of compliance shall be provided upon request and shall be appropriate to the application's risk and software delivery model.

5.0 Directives

5.1 Governance

5.1.1 Software developed, acquired, configured, hosted, maintained, or operated on behalf of the State of Maine shall follow an approved Secure Software Development Lifecycle (SSDLC).

5.1.2 Security shall be integrated throughout the software lifecycle and considered during planning, acquisition, design, development, implementation, operation, maintenance, and retirement.

5.1.3 Security responsibilities shall be clearly defined for organizations and individuals participating in software delivery.

5.1.4 The depth and rigor of security activities shall be commensurate with the application's risk, as determined by the Application Risk Profile (ARP).

5.2 Security Requirements

5.2.1 Security and privacy requirements shall be identified and considered throughout the software lifecycle.

5.2.2 Applications shall comply with applicable State of Maine policies, security standards, contractual obligations, regulatory requirements, and applicable laws.

5.2.3 Security requirements shall be incorporated into software acquisition, development, configuration, implementation, and operational planning activities.

5.3 Secure Software Delivery

5.3.1 Software shall be designed, developed, acquired, configured, and maintained using practices that reduce security risk throughout the lifecycle.

5.3.2 Security controls shall be selected based on application risk, business requirements, architecture, and software delivery model.

5.3.3 Supporting Standards shall define the minimum-security controls applicable to different software delivery models, including internally developed applications, vendor-developed software, vendor-hosted services, commercial software, and low-code/no-code solutions.

5.4 Security Verification

5.4.1 Applications shall undergo security verification activities appropriate to their Application Risk Profile (ARP) and software delivery model before implementation and throughout the application lifecycle.

5.4.2 Security verification shall be sufficient to provide reasonable assurance that security requirements have been satisfied and identified risks have been appropriately addressed.

5.4.3 Supporting Standards establish the minimum-security verification activities applicable to each software delivery model and application risk level.
5.4.4 Identified security findings shall be evaluated and managed in accordance with the State of Maine's Vulnerability Management Policy and supporting Standards.

5.5 **Software Supply Chain Security**
5.5.1 Software acquired or developed for the State of Maine shall be managed to reduce supply chain risk.
5.5.2 Organizations shall evaluate software components, dependencies, third-party services, and externally developed software in accordance with applicable procurement, third-party risk management, and security requirements.

5.6 **Deployment and Change Management**
5.6.1 Software shall be deployed through approved implementation and change management processes.
5.6.2 Production changes shall not be implemented until required security activities have been completed or appropriate exceptions have been approved.

5.7 **Operational Security**
5.7.1 Applications shall be monitored throughout their operational lifecycle to identify newly discovered security risks and vulnerabilities.
5.7.2 Security vulnerabilities shall be evaluated and addressed in accordance with applicable enterprise policies and standards.
5.7.3 Security incidents involving software shall be managed through the State of Maine's Incident Response process.

5.8 **Compliance Evidence**
5.8.1 Organizations responsible for software delivery shall maintain documentation and evidence sufficient to demonstrate compliance with this Policy.
5.8.2 The type and amount of evidence required shall be commensurate with the application's risk and software delivery model.
5.8.3 Evidence may include documentation of security requirements, risk assessments, design reviews, testing results, approvals, vendor attestations, exception approvals, or other records demonstrating compliance with this Policy.

5.9 **Equivalent Security Outcomes**
5.9.1 The State of Maine recognizes that software delivery models differ in their ability to implement identical technical controls.
5.9.2 Where prescribed technical controls cannot reasonably be implemented because of technology platforms, software delivery models, hosting environment, or vendor constraints, equivalent or compensating controls may be used, provided they achieve the security objectives established by this Policy and are implemented in accordance with approved Standards and the State of Maine's exception management process.

5.10 **Exceptions/Waivers**
5.10.1 Exceptions to this Policy shall be documented, reviewed, approved, and periodically reassessed in accordance with the State of Maine's approved exception management process.
5.10.2 Approved exceptions shall include documented business justification, risk

acceptance, and any required compensating controls.

5.11 **Compliance**

5.11.1 Compliance with this Policy shall be demonstrated through governance, operational, and technical evidence appropriate to the application's risk and software delivery model.

5.11.2 Compliance may be assessed through one or more of the following:

5.11.2.1 Governance and compliance reviews.
5.11.2.2 Security assessments and testing activities.
5.11.2.3 Documentation and evidence reviews.
5.11.2.4 Automated security tooling, where applicable.
5.11.2.5 Repository, configuration, or implementation reviews.
5.11.2.6 Internal or external audits.
5.11.2.7 Vendor-provided security documentation or attestations.
5.11.2.8 Other approved methods that demonstrate compliance with this Policy.

5.11.3 Organizations responsible for software delivery shall maintain sufficient documentation to demonstrate compliance with this Policy and supporting Standards.

5.11.4 Failure to comply with this Policy may result in remediation activities, corrective action plans, acceptance of risk through the approved exception process, or other actions consistent with State of Maine policies and governance requirements.

5.11.5 Compliance with this Policy shall be evaluated in conjunction with the supporting Standards and Procedures that establish the minimum-security controls applicable to the application's risk and software delivery model.

6.0 Supporting Documentation

6.1 This Policy is supported by Standards, Procedures, Templates, Playbooks, and Technical Guidance that define the minimum-security requirements and implementation practices necessary to satisfy the SDLC and the SSDLC.

6.2 These supporting documents are maintained by ISO and ESS as part of a growing documentation library and may be updated independently of this Policy to reflect changes in technology, threats, and software delivery practices.

6.3 All current and planned SDLC and SSDLC supporting materials are located within the SSDLC documentation library[3], and by being published there, are considered part of this Policy. Supporting documentation may include, but is not limited to:

6.4 **Security Standards**

6.4.1 Application Risk Profile (ARP) Standard
6.4.2 Secure Software Development Standard
6.4.3 Secure Coding Standard
6.4.4 Security Testing Standard
6.4.5 Secure Build and Release Standard

[3] https://stateofmaine.sharepoint.com/sites/MaineIT-SSDLC-COE/Shared%20Documents/Forms/AllItems.aspx

6.4.6 Secure Logging Standard
6.4.7 Secrets Management Standard
6.4.8 Software Supply Chain Security Standard
6.4.9 Repository Governance Standard
6.4.10 Vendor Software Security Standard
6.4.11 Low-Code / No-Code Security Standard

6.5 **Procedures**
6.5.1 Secure Software Development Procedures
6.5.2 Security Verification Procedures
6.5.3 Secure Deployment Procedures
6.5.4 Vulnerability Remediation Procedures

6.6 **Templates, Playbooks, and Technical Guidance**
6.6.1 Threat Modeling Template
6.6.2 Secure Design Checklist
6.6.3 Security Review Checklist
6.6.4 Secure Pull Request Guidance
6.6.5 Developer Quick Start Guides
6.6.6 Secure Coding Reference Materials
6.6.7 Security Champion Guidance
6.6.8 Vendor Security Assessment Guidance

6.7 **Related State of Maine OIT Policies**: This Policy should be implemented in conjunction with applicable State of Maine policies and procedures, including but not limited to:
6.7.1 Information Security Policy[4]
6.7.2 Vulnerability Scanning Procedures (RA-5)[5]
6.7.3 Supply Chain Risk Management Policy and Procedures (SR-1)[6] (Internal only)
6.7.4 Change Management Policy and Procedures
6.7.5 Cyber Incident Response Policy and Procedures (IR)[7] (Internal only)
6.7.6 Risk Assessment Policy and Procedures (RA-1)[8] (Internal only)
6.7.7 Waiver Policy[9]

6.8 **External References**: This Policy is informed by recognized industry frameworks and guidance, including:
6.8.1 NIST Special Publication 800-218 – Secure Software Development Framework (SSDF)[10]
6.8.2 NIST Special Publication 800-53 Rev. 5 – Security and Privacy Controls for Information Systems and Organizations[11]

[4] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SecurityPolicy.pdf
[5] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/VulnerablityScanningProcedure.pdf
[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SupplyChainRiskManagementPolicy.pdf
[7] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ChangeManagementPolicy.pdf
[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/RiskAssessmentPolicyProcedure.pdf
[9] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/Waiver.pdf
[10] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-218.pdf
[11] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf

6.8.3 NIST Special Publication 800-161 Rev. 1 – Cybersecurity Supply Chain Risk Management[12]
6.8.4 NIST Cybersecurity Framework (CSF) 2.0[13]
6.8.5 OWASP Software Assurance Maturity Model (SAMM)[14]
6.8.6 OWASP Application Security Verification Standard (ASVS)[15]
6.8.7 OWASP Top Ten[16]
6.8.8 CISA Secure by Design[17]
6.8.9 CISA Secure by Default[18]
6.8.10 CISA Secure Software Development Guidance[19]

7.0 Document Information

Initial Issue Date: August 31, 2009
Last Revision Date: October 16, 2026
Point of Contact: PolicyTeam.OIT@Maine.Gov
Approved By: Chief Information Officer, OIT
Legal Citation: Title 5, Chapter 163: Office of Information Technology[20].
Waiver Process: See the Waiver Policy[21].

[12] https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-161r1-upd1.pdf
[13] https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf
[14] https://owasp.org/www-project-samm/
[15] https://owasp.org/www-project-application-security-verification-standard/
[16] https://owasp.org/www-project-top-ten/
[17] https://www.cisa.gov/sites/default/files/2023-10/Shifting-the-Balance-of-Cybersecurity-Risk-Principles-and-Approaches-for-Secure-by-Design-Software.pdf
[18] https://www.cisa.gov/sites/default/files/2023-10/Shifting-the-Balance-of-Cybersecurity-Risk-Principles-and-Approaches-for-Secure-by-Design-Software.pdf
[19] https://media.defense.gov/2022/Sep/01/2003068942/-1/-1/0/ESF_Securing_The_Software_Supply_Chain_Developers.PDF
[20] http://legislature.maine.gov/statutes/5/title5ch163sec0.html
[21] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf